重大 AI 更新提醒

10-27 | diffusers 安全补丁：修复 from_pretrained 组件解析，防止 trust_remote_code 绕过

本期导读

本期聚焦 Hugging Face diffusers 发布的安全补丁 v0.42.1。该版本修复了 from_pretrained 加载时组件库名解析逻辑，避免攻击者利用声明类名绕过 trust_remote_code 限制执行任意代码。所有使用 0.42.0 的开发者应尽快升级。

已检查来源

GitHub Release: huggingface/diffusers v0.42.1

1. huggingface/diffusers v0.42.1 安全发布：修复 from_pretrained 组件解析防止 trust_remote_code 绕过

来源 GitHub Release | 类型 GitHub Release | 主题 检索增强与向量模型 时间 10-27 02:41 | 分数 7

是什么

这是 Hugging Face diffusers 库的补丁版本 v0.42.1，属于安全发布。它修复了在调用 from_pretrained 加载 DiffusionPipeline、AutoModel 或 ModularPipeline 时，对组件声明的库名（library name）的解析方式。此前，模型或流水线在 model_index.json / config.json 中把每个组件声明为 库名 类名 对，v0.42.1 改变了该库名的解析路径，并在解析后的模块中找不到声明的类时给出更清晰的错误提示。

通俗解释

你可以把 diffusers 的加载过程想象成按说明书组装家具：说明书（model_index.json）上写着每个零件来自哪个品牌（库名）和叫什么（类名）。旧版在核对品牌时可能被恶意说明书误导，把本应被安全锁（trust_remote_code）拦住的零件偷偷装进来。v0.42.1 相当于升级了核对流程，严格按真实品牌找零件，找不到就明确报错，而不是悄悄放行。

主要作用

解决 from_pretrained 加载路径中组件库名解析可能被滥用、从而绕过 trust_remote_code 安全限制的问题，防止加载不可信模型时执行未授权代码，保护使用 diffusers 的开发者与生产环境。

核心功能

1) 统一修正 DiffusionPipeline、AutoModel、ModularPipeline 三条加载路径的组件库名解析逻辑；2) 当声明的类在解析后的模块中不存在时，抛出更清晰的错误信息，便于排查；3) 作为安全补丁发布，附带 GHSA-4prv-5hj7-c2xr 安全公告；4) 升级方式简单，pip install diffusers==0.42.1 即可。

对比判断

候选摘要未提供与旧版本的 benchmark、速度或成本对比数据；该版本为安全修复，暂无可信公开性能对比数据。

适合谁

适合所有使用 Hugging Face diffusers 加载扩散模型或流水线的开发者、研究者和 MLOps 团队，尤其是会加载第三方或社区上传模型、依赖 trust_remote_code 安全边界的生产环境。

直达链接 https://github.com/huggingface/diffusers/releases/tag/v0.42.1

本期仅一条候选，聚焦安全修复；建议 diffusers 0.42.0 用户立即升级至 0.42.1。